

The Basics of Vulnerability Assessment and Penetration Testing

In these days of widespread Internet usage, security is of prime importance. The almost universal use of mobile and Web applications makes systems vulnerable to cyber attacks. Vulnerability assessment can help identify the loopholes in a system while penetration testing is a proof-of-concept approach to actually explore and exploit a vulnerability.



Cyber attacks are increasing every day with the increased use of mobile and Web applications.

Globally, statistics show that more than 70 per cent of the applications either have vulnerabilities which could potentially be exploited by a hacker, or worse, they have already been exploited. The data losses due to this are typically of two types. Either the data is confidential to the organisation or it is private to an individual. Regardless of the category, data losses result in the loss of money or reputation. This article explores a technical process that can be adopted by industries and organisations to protect their intellectual property, and if implemented correctly, will result in better risk management.

For those who are new to Vulnerability Assessment and Penetration Testing (VAPT), this is a technical assessment process to find security bugs in a software program or a computer network. The network may be a LAN or WAN, while the software program can be a .exe running on a server or desktop, a Web/cloud application or a mobile application. Before we get into the technical aspects of VAPT, let's look at a few of its benefits.

- Helps identify programming errors that can lead to cyber attacks
- Provides a methodical approach to risk management
- Secures IT networks from internal and external attacks
- Secures applications from business logic flaws
- Increased ROI on IT security
- Protects the organisation from loss of reputation and money

Why are systems vulnerable?

There are primarily two main reasons for systems being vulnerable—misconfiguration and incorrect programming practices. In the case of networks, devices such as routers, switches and servers, as well as firewalls and IPS systems are either misconfigured or, in some cases, not configured at all, thus running default settings. As an example, almost all firewalls have a default built-in user account with the name, 'admin'. Typically, the password for it is also set to 'admin,' by default, or something even easier to guess. Looking at the example of servers, installing a database server leaves us with an 'sa' account, which has a blank password.